NAME: AGBOOLA BLESSING GBEMISOLA

MATRIC NO: RUN/CYB/23/15378

VULNERABILITY: Log4Shell(CVE-2021-44228)

Log4Shell is a vulnerability found in Apache Log4j 2, a logging library used by Java applications. It became publicly known in December 2021. The vulnerability is dangerous because an attacker could exploit it to execute malicious code remotely on a vulnerable system. This could expose sensitive information or allow the attacker to interfere with the system.

According to the National Vulnerability Database (NVD), CVE-2021-44228 affects the log4j-core component of Apache Log4j 2. The vulnerability occurs because certain versions of Log4j do not properly protect against malicious input that triggers unsafe JNDI (Java Naming and Directory interface) lookups. An attacker who can control the information being logged may exploit this weakness to execute code on the affected system.

Vulnerability details from NVD are;

Item	**Details**
Vulnerability name	Log4Shell
CVE ID	CVE-2021-44228
Affected software	Apache Log4j 2
Affected component	log4j-core
Vulnerability type	Remote Code Execution (RCE)
Severity	Critical
CVSS v3.1 score	10.0 out of 10
Attack vector	Network
Privileges required	None
User interaction	None

Patch for the vulnerability

Apache released Log4j 2.15.0 as the initial fix for CVE-2021-44228 for Java 8 and later. However, the fix was incomplete in some configurations, leading to further security issues. Apache subsequently released Log4j 2.16.0, which removed the vulnerable lookup functionality.

For actual protection today, organisations should use a currently supported, secure Log4j release rather than relying on these old versions.

Severity score

The NVD assigns CVE-2021-44228 a CVSS v3.1 score of 10.0, which is Critical and the highest possible score. This vulnerability can be exploited over a network and does not require prior privileges.

Log4Shell Using the Cyber Kill Chain and Cybersecurity Expert Response

1. Reconnaissance

At this stage, the attacker gathers information about the target system and looks for applications that may be using vulnerable versions of Apache Log4j. The attacker may search for exposed servers or services that use the affected library.

Cybersecurity expert's response: The expert should identify applications using Log4j, check their versions and determine which systems are exposed to attack.

2. Weaponisation

The attacker prepares input intended to exploit the weakness in Log4j's JNDI lookup functionality.

Cybersecurity expert's response: The expert should identify the vulnerable software, assess the risk and ensure that the appropriate security updates are available and ready to be applied.

3. Delivery

The attacker sends specially crafted input to an application that uses a vulnerable version of Log4j. This input may be processed when the application records information in its logs.

Cybersecurity expert's response: The expert should monitor application logs, web requests and network traffic for suspicious input or unexpected connections to external systems.

4. Exploitation

The vulnerable Log4j component processes the malicious input. Under the affected conditions, this can allow the attacker to execute code remotely on the system. The NVD identifies this as a remote code execution vulnerability.

Cybersecurity expert's response: The expert should apply the appropriate Log4j security update as soon as possible. If a system is suspected of being compromised, it should be isolated where necessary while an investigation is carried out.

5. Installation

If the attacker successfully exploits the vulnerability, they may attempt to install malware or establish a way to maintain access to the affected system. This stage may occur after successful exploitation, but it is not an automatic result of Log4Shell.

Cybersecurity expert's response: The expert should inspect the system for suspicious files, unauthorised programs, unexpected services and other signs of unauthorised changes.

6. Command and Control

At this stage, an attacker who has gained access may attempt to communicate with the compromised system through an external server to send commands or receive information.

Cybersecurity expert's response: The expert should investigate unusual outbound connections, block confirmed malicious communications and monitor the affected system for further suspicious activity.

7. Actions on Objectives

At the final stage, the attacker attempts to achieve their goal. This could involve stealing confidential information, changing data, disrupting services or gaining access to other systems.

Cybersecurity expert's response: The expert should contain the incident, remove malicious activity, protect affected accounts and credentials, restore systems safely and continue monitoring for further attacks.

References

National Institute of Standards and Technology. (n.d.). *CVE-2021-44228 detail*. National Vulnerability Database. https://nvd.nist.gov/vuln/detail/CVE-2021-44228

Apache Software Foundation. (n.d.). *Security*. Apache Logging Services. https://logging.apache.org/security.html

Cybersecurity and Infrastructure Security Agency. (2021, December 22). *Mitigating Log4Shell and other Log4j-related vulnerabilities*. https://content.govdelivery.com/accounts/USDHSCISA/bulletins/302282c